시스템접근권한관리기준

문서번호: HB-SEC-101
보안등급: 비밀
시행일: 2025-09-15
개정차수: 1

제1조(목적)

이 기준은 한빛시장정보(주)(이하 "회사"라 한다)의 정보 시스템에 대한 접근 권한의 부여, 변경, 회수와 점검에 필요한 사항을 정하여 정보 자산을 무단 접근으로부터 보호함을 목적으로 한다.

이 기준은 회사의 모든 임직원과 정보 시스템에 접근하는 외부 위탁 인력에게 적용한다.

이 기준은 정보보호규정과 함께 적용하되, 접근 권한의 관리에 관하여는 이 기준을 우선한다.

제2조(정의)

이 기준에서 사용하는 용어의 뜻은 다음과 같다.

1. "접근 권한"이란 정보 시스템과 데이터에 접속하여 조회, 입력, 수정, 삭제 등을 할 수 있는 권리를 말한다.

2. "관리자 계정"이란 시스템의 설정을 변경하거나 다른 계정의 권한을 부여할 수 있는 높은 권한의 계정을 말한다.

3. "최소 권한 원칙"이란 업무 수행에 필요한 최소한의 권한만 부여하는 원칙을 말한다.

4. "접근 로그"란 시스템 접속과 작업 내역을 자동으로 남긴 기록을 말한다.

5. "정보보호최고책임자"란 회사의 정보보호 업무를 총괄하는 임원을 말한다.

제3조(접근 권한 부여의 원칙)

접근 권한은 최소 권한 원칙에 따라 업무 수행에 필요한 범위에서만 부여한다.

한 사람이 입력과 승인 같이 서로 견제가 필요한 권한을 함께 갖지 않도록 업무와 권한을 분리한다.

권한 부여를 요청하는 사람은 업무상 필요한 이유와 사용 기간을 명시하여야 한다.

부여된 권한은 요청한 사용 기간이 끝나면 자동으로 소멸하도록 설정하며, 기간을 연장하려면 부서장이 사유를 적어 다시 요청하여야 한다.

비밀 등급 문서가 저장된 시스템에 대한 권한은 부서장의 요청과 정보보호팀장의 확인을 모두 거친 경우에만 부여한다.

제4조(일반 계정의 발급)

일반 계정은 소속 부서장의 요청과 정보보호팀장의 확인을 거쳐 발급한다.

일반 계정은 사용자 1명당 1개를 원칙으로 하며, 여러 사람이 하나의 계정을 공유해서는 안 된다.

신규 입사자의 계정은 입사일에 발급하고, 최초 접속 시 비밀번호를 바꾸도록 한다.

계정 발급 요청서에는 사용자의 소속, 직위, 접근이 필요한 시스템과 권한의 범위, 사용 목적을 적어야 한다.

정보보호팀은 요청 내용이 최소 권한 원칙에 맞는지 확인하고, 맞지 않으면 요청을 반려하거나 권한의 범위를 조정할 수 있다.

제5조(관리자 계정)

관리자 계정 발급은 정보보호최고책임자(CISO) 승인을 받아야 한다.

관리자 계정은 시스템별로 담당자를 지정하여 관리하며, 담당자 이외의 사람이 사용해서는 안 된다.

관리자 계정으로 수행한 모든 작업은 접근 로그에 기록되어야 하며, 정보보호팀은 그 내용을 주 1회 점검한다.

관리자 계정의 사용 기간은 발급일부터 6개월로 하고, 계속 사용이 필요하면 다시 승인을 받는다.

관리자 계정의 비밀번호는 정보보호팀이 지정한 보관 장소에 봉인하여 보관하며, 비상시 사용 후에는 즉시 새 비밀번호로 변경한다.

관리자 계정을 새로 발급하거나 회수한 경우 정보보호팀은 그 내용을 관리자 계정 관리 대장에 기록한다.

제6조(외부 인력의 접근)
외부 위탁 인력에게는 계약 기간 안에서 필요한 시스템에 한하여 임시 계정을 발급한다.
임시 계정의 유효 기간은 최대 90일로 하며, 계약이 끝나거나 업무가 종료되면 즉시 회수한다.
외부 인력의 접근은 회사가 지정한 원격 접속 수단으로만 허용하고, 작업 전 보안 서약서를 제출받는다.
외부 인력이 접근할 수 있는 시스템에서는 비밀 등급 문서와 개인정보가 저장된 영역을 제외한다.
외부 인력의 작업 내용은 회사 담당 직원이 확인하고, 작업이 끝나면 작업 결과와 접근 기록을 정보보호팀에 제출한다.

제7조(권한의 변경과 회수)
직원의 부서 이동이나 직무 변경이 있는 경우 소속 부서장은 변경일부터 3영업일 이내에 기존 권한의 회수와 새로운 권한의 부여를 요청하여야 한다.
퇴직자의 계정은 퇴직일 당일에 잠금 처리하고, 30일이 지난 뒤 삭제한다.
장기 휴직자의 계정은 휴직 개시일에 일시 정지한다.
권한 회수를 요청하지 않아 퇴직자나 이동자의 권한이 남아 있는 사실이 발견되면, 정보보호팀은 해당 부서장에게 경위를 확인하고 즉시 권한을 회수한다.
권한의 변경과 회수 내역은 계정 관리 대장에 기록하여 보관한다.

제8조(접근 로그)
접근 로그는 접속 일시, 사용자, 접속 위치, 수행 작업을 포함하여 기록한다.
접근 로그는 2년 보존하며, 보존 기간 동안 임의로 수정하거나 삭제할 수 없도록 보호한다.
정보보호팀은 이상 징후가 있는 접근 로그를 확인한 즉시 정보보호최고책임자에게 보고한다.
접근 로그는 시스템별로 중앙 로그 저장소에 모아 보관하며, 저장소에 대한 관리자 권한은 정보보호팀의 지정된 담당자에게만 부여한다.
접근 로그의 보존 기간이 끝나면 정보보호팀장의 승인을 받아 복구할 수 없는 방법으로 삭제한다.

제9조(비밀번호와 인증)
모든 계정은 일정한 길이와 복잡도를 갖춘 비밀번호를 사용하여야 한다.
관리자 계정과 외부에서 접속하는 모든 계정에는 2단계 인증을 적용한다.
비밀번호를 연속하여 5회 틀리면 계정이 잠기며, 잠금 해제는 본인 확인을 거쳐 정보보호팀이 처리한다.
비밀번호를 포함한 인증 정보는 다른 사람에게 알려 주거나 메모로 남겨서는 안 된다.
인증 정보가 노출되었거나 노출이 의심되는 경우에는 즉시 비밀번호를 변경하고 정보보호팀에 알려야 한다.

제10조(권한 재검토)
정보보호팀은 분기 1회 전체 계정과 권한의 적정성을 재검토한다.
재검토 결과 업무상 필요가 없어진 권한은 부서장의 확인을 받아 즉시 회수한다.
90일 이상 사용 기록이 없는 계정은 휴면 계정으로 분류하여 잠금 처리한다.
재검토 결과는 정보보호최고책임자에게 보고한다.
재검토 과정에서 부서장은 소속 직원별 권한 목록을 확인하고 서명하여 정보보호팀에 제출한다.
정보보호팀은 재검토에서 확인된 부적절한 권한 부여 사례를 분석하여 교육 자료에 반영한다.

제11조(위반 시 조치)
이 기준을 위반하여 접근 권한을 부정하게 사용한 사람은 사규에 따라 징계할 수 있다.
위반으로 인하여 회사에 손해가 발생한 경우에는 그 책임을 물을 수 있다.

부칙
이 기준은 2025-09-15부터 시행한다.